Laboratorium nr 5 – Poziomy TRL 1, 2, 3 i 4

Aplikacja webowa do szyfrowanych notatek

Zespół: Wiktor Dąbrowski / Krystian Czajkowski
Kierownik projektu: nie robimy jak w valve - wiktor
Data: 21.10.2026

1. Poziom TRL 1 – badania podstawowe

1.1. Opis idei

W wyniku analiz informatycznych zespół opracował koncepcję aplikacji webowej do przechowywania notatek, w której treść jest szyfrowana po stronie użytkownika, zanim opuści przeglądarkę. Serwer przechowuje wyłącznie zaszyfrowane dane i nie ma technicznej możliwości ich odczytania, nawet w razie włamania do bazy lub dostępu administratora (model zero-knowledge).

Wstępne obserwacje wskazują, że współczesne przeglądarki udostępniają mechanizmy kryptograficzne (Web Crypto API) umożliwiające szyfrowanie standardowymi algorytmami (np. AES-GCM) bez instalowania dodatkowego oprogramowania. Klucz szyfrujący może być wyprowadzany z hasła użytkownika funkcją do tego przeznaczoną (np. PBKDF2 lub Argon2), dzięki czemu hasło nie jest przesyłane na serwer w postaci jawnej.

1.2. Potencjalne zastosowania

Na tym etapie nie było jeszcze określone, jaki konkretny produkt powstanie. Zidentyfikowano następujące potencjalne zastosowania:

- osobisty notatnik dla osób dbających o prywatność,
- bezpieczne przechowywanie danych wrażliwych (hasła, dane medyczne, dokumentacja),
- narzędzie dla małych zespołów lub organizacji bez własnej infrastruktury bezpieczeństwa,
- współdzielone notatki szyfrowane end-to-end.

1.3. Zagadnienia do rozstrzygnięcia

- sposób odzyskiwania dostępu po utracie hasła (przy modelu zero-knowledge brak hasła oznacza utratę danych),
- możliwość wyszukiwania w zaszyfrowanych notatkach,
- bezpieczne udostępnianie notatek innym użytkownikom.

2. Poziom TRL 2 – badania przemysłowe

2.1. Koncepcja technologii i jej przyszłego zastosowania

Przeprowadzono wstępną analizę możliwych zastosowań technologii szyfrowania notatek po stronie klienta. Ustalono, że optymalnym rozwiązaniem jest aplikacja webowa dostępna w nowoczesnych przeglądarkach na komputerach i urządzeniach mobilnych, dzięki czemu nie ma potrzeby tworzenia osobnych wersji na poszczególne systemy operacyjne (Windows, Linux, Android, iOS).

Aplikacja będzie składać się z dwóch części: interfejsu działającego w przeglądarce, który odpowiada za szyfrowanie i odszyfrowywanie notatek, oraz serwera z API i bazą danych, który przechowuje wyłącznie dane zaszyfrowane. Interfejs powinien być prosty i intuicyjny, zgodnie z zasadą: im mniej kroków do rezultatu, tym lepiej. Utworzenie, zapisanie i odczytanie notatki powinno wymagać możliwie najmniejszej

liczby kliknięć, a szyfrowanie ma działać w sposób niewidoczny dla użytkownika po jednorazowym podaniu hasła.

Jako główny kierunek rozwoju przyjęto osobisty notatnik dla użytkowników ceniących prywatność, z możliwością rozbudowy o bezpieczne przechowywanie danych wrażliwych. Opcja uruchamiania własnej instancji aplikacji w kontenerach Docker zostanie rozważona jako jeden z wariantów wdrożenia dla małych zespołów.

2.2. Lista rzeczy potrzebnych do dalszego rozwoju projektu

- środowisko do testów (kontenery Docker Compose odwzorowujące środowisko produkcyjne),
- 2x stanowisko programistyczne z nowoczesnym środowiskiem programistycznym (np. VS Code lub PyCharm),
- repozytorium kodu Git z automatyczną integracją i testami (CI),
- serwer (VPS) z dostępem do Internetu, własną domeną i certyfikatem TLS (HTTPS),
- baza danych PostgreSQL,
- biblioteki kryptograficzne (Web Crypto API, implementacja Argon2) wraz z dokumentacją standardów,
- narzędzia do testów bezpieczeństwa (np. OWASP ZAP) oraz konsultacja lub przegląd rozwiązań kryptograficznych,
- urządzenia i przeglądarki testowe (desktop i mobilne),
- narzędzie do zarządzania zadaniami w zespole (np. Trello lub Jira).

3. Poziom TRL 3 – badania przemysłowe

3.1. Zakres prac badawczych

W ramach realizacji III poziomu gotowości technologicznej zostaną zrealizowane prace badawcze, których celem jest potwierdzenie założeń koncepcji. Poszczególne moduły będą badane osobno, bez łączenia ich w całość, w następującym zakresie:

- Moduł szyfrowania i odszyfrowywania w przeglądarce – szyfrowanie notatek algorytmem AES-GCM z wykorzystaniem Web Crypto API. Szczególny nacisk zostanie położony na poprawność danych po odszyfrowaniu. Moduł zostanie wyposażony w mechanizm porównywania odszyfrowanej treści z oryginałem, a miarą końcową będzie współczynnik zgodności wyrażony w procentach. Zbadany zostanie również wpływ wielkości notatki na czas szyfrowania i odszyfrowywania.
- Moduł wyprowadzania klucza z hasła – wyprowadzanie klucza szyfrującego funkcją Argon2 lub PBKDF2. Badania skupią się na znalezieniu optymalnego punktu parametrów funkcji: czas wyprowadzania klucza na typowych urządzeniach (w tym mobilnych) ma być akceptowalny dla użytkownika, a jednocześnie wystarczająco kosztowny dla potencjalnego atakującego.
- Moduł przechowywania zaszyfrowanych danych – serwer z API i bazą PostgreSQL przyjmujący i udostępniający wyłącznie dane zaszyfrowane. Zostanie zweryfikowane, że w bazie danych nie występuje żadna treść notatek w postaci jawnej, oraz zbadana wydajność zapisu i odczytu w zależności od liczby i wielkości notatek.
- Moduł uwierzytelniania – logowanie użytkownika bez przesyłania hasła w postaci jawnej na serwer. Zostanie sprawdzona możliwość rozdzielenia danych służących do uwierzytelnienia od materiału służącego do wyprowadzenia klucza szyfrującego.

Na poziomie wskazanego etapu zostanie również opracowany model analityczny odporności na atak siłowy (brute force), wyrażający czas potrzebny na odgadnięcie hasła w zależności od jego długości oraz parametrów funkcji wyprowadzania klucza. Posłuży on do doboru parametrów bezpieczeństwa aplikacji.

4. Poziom TRL 4 – badania przemysłowe

4.1. Weryfikacja koncepcji w warunkach laboratoryjnych

W ramach realizacji IV poziomu gotowości technologicznej zostaną zrealizowane prace badawcze, w których zintegrowane moduły prototypu będą testowane w warunkach laboratoryjnych, w następującym zakresie:

- Moduł szyfrowania i odszyfrowywania – przygotowano zestaw kontrolny 100 notatek o zróżnicowanej długości (od kilku znaków do kilkuset kilobajtów), w tym zawierających polskie znaki diakrytyczne i znaki specjalne. Wykonano 100 serii testów cyklu szyfrowanie – odszyfrowanie, a odszyfrowaną treść porównano z oryginałem. Algorytm wykazał odchylenia w niektórych seriach, w których notatki zawierały znaki spoza podstawowego zestawu. Ustalono, że na wynik ma wpływ sposób kodowania znaków przed szyfrowaniem. Wprowadzono poprawkę (jawne kodowanie UTF-8) i ponownie wykonano 100 serii testów. Wyniki w całej serii były zgodne z oryginałem, a odchylenia zostały wyeliminowane.
- Moduł wyprowadzania klucza z hasła – wykonano 100 serii pomiarów czasu wyprowadzania klucza dla kilku zestawów parametrów funkcji na różnych urządzeniach (komputer stacjonarny, laptop, telefon). Zebrane dane posłużyły do sporządzenia wykresów zależności czasu od parametrów. Ustalono, że czas na urządzeniach mobilnych jest wielokrotnie dłuższy niż na komputerze, w związku z czym wybrano parametry stanowiące kompromis pomiędzy komfortem użytkownika a odpornością na atak siłowy, zgodnie z modelem opracowanym na poziomie TRL 3.
- Moduł przechowywania zaszyfrowanych danych – przesłano przez API do bazy 100 zaszyfrowanych notatek, a następnie przeszukano zawartość bazy danych pod kątem fraz z oryginalnych notatek. W bazie nie stwierdzono treści w postaci jawnej. Wykazano natomiast, że w trybie debugowania logi aplikacji mogą zawierać fragmenty przesyłanych danych. Zmieniono konfigurację logowania i ponownie wykonano test, a wyniki nie wykazały już żadnych jawnych danych. Zmierzono także czas zapisu i odczytu w zależności od liczby i wielkości notatek.
- Moduł uwierzytelniania – wykonano 100 serii logowania z poprawnymi i błędnymi hasłami, a ruch sieciowy zbadano pod kątem obecności hasła w postaci jawnej. Hasła w ruchu nie stwierdzono. Zauważono niewielką różnicę czasu odpowiedzi serwera dla poprawnych i niepoprawnych danych, która mogłaby ułatwić atak. Wprowadzono porównywanie danych w stałym czasie i powtórzono testy, a różnice zostały zminimalizowane.
- Test zintegrowany – wykonano 100 serii pełnego cyklu: podanie hasła, wyprowadzenie klucza, szyfrowanie notatki, wysłanie na serwer, pobranie, odszyfrowanie. Miarą końcową był współczynnik zgodności odszyfrowanej treści z oryginałem wyrażony w procentach.

4.2. Ryzyka i sposoby ich eliminacji

Ryzyka uporządkowano według szacowanego prawdopodobieństwa wystąpienia. Ryzyka o najwyższym wskaźniku procentowym są eliminowane w pierwszej kolejności.

Ryzyko	Szansa wystąpienia	Rozwiązanie
Zbyt długi czas wyprowadzania klucza na słabszych urządzeniach, skutkujący wolnym logowaniem.	40%	Rozszerzenie testów o różne klasy urządzeń (w tym starsze telefony) i dobór parametrów funkcji jako kompromisu pomiędzy czasem a bezpieczeństwem.
Niekompatybilność danych pomiędzy modułami (kodowanie znaków, format szyfrogramu, sól i wektor inicjujący), uniemożliwiająca odszyfrowanie notatki.	30%	Zdefiniowanie jednego, jednoznacznego formatu paczki z szyfrogramem oraz zaprogramowanie automatycznych testów integracyjnych z użyciem polskich znaków i znaków specjalnych.
Różnice w działaniu Web Crypto API w różnych przeglądarkach.	25%	Rozszerzenie testów o przeglądarki desktopowe i mobilne (Chrome, Firefox, Safari) oraz wydzielenie warstwy abstrakcji nad operacjami kryptograficznymi.
Wyciek danych w postaci jawnej na serwerze przez logi lub metadane.	20%	Przegląd konfiguracji logowania, wyłączenie zapisu treści żądań oraz testy automatyczne przeszukujące bazę i logi pod kątem jawnych danych.

5. Skład zespołu i role

Zespół liczy dwie osoby. Obowiązki kierownika projektu (koordynacja prac, pilnowanie terminów, prezentacja wyników) są dodatkiem do roli technicznej.

Rola	Zakres odpowiedzialności
Kierownik projektu + backend i bezpieczeństwo	Koordynacja zespołu i terminów, prezentacja; API w Django, przechowywanie zaszyfrowanych danych, uwierzytelnianie
Frontend i kryptografia	Interfejs użytkownika, szyfrowanie i odszyfrowywanie po stronie przeglądarki, wyprowadzanie klucza z hasła